

Stoquify Blocker and Gate Control Plane — technical feasibility assessment

Architecture, security, data, workflow, threat and G1 pilot feasibility

TECHNICAL FEASIBILITY ASSESSMENT

Prepared 2026-08-19

Evidence-bound | approval-gated | fail-closed

No production claim without authentic evidence.

Prepared: 2026-08-19 Assessment scope: repository architecture, security, data, workflow, operations and G1 pilot feasibility Implementation performed: none Production authorization: false Feasibility verdict: **technically feasible as a modular-monolith extension; standalone service not justified now**

Verdict

Stoquify can build the proposed capability without replacing its authentication, RBAC, assurance, evidence, event, POS, accounting or other domain systems. The lowest-risk boundary is an additive set of modules under `services/assurance/`, protected by existing server actions and projected into the existing Assurance Control Tower.

Feasibility is **medium-high** because important primitives are already implemented and tested. Delivery risk is still material because the missing parts sit on a high-trust boundary: authority, approval intent, canonical hashes, immutable evidence, independent verification and invalidation. Governance uncertainty—not raw coding difficulty—is the first blocking dependency.

Evidence-first baseline

Live validation on 2026-08-19

Independent SHA-256 of frozen G1 JSON	11434eb3e1af1826516426e90d2d53a2faa47ade361d91191b5f3e0c950a36db	Matches the expected contract binding.
<code>npm run pos:g1:contract:gate</code>	Exit 1, expected blocked	13/13 technical checks pass; D-01–D-11 remain pending; approval status 0/11.
<code>npm run pos:enterprise:program:gate</code>	Exit 1, expected blocked	Program controller ready; 0/10 gates; G1 first; 0/9 external evidence verified.
<code>npm run prisma:validate</code>	Pass	Current schema is valid.
<code>npm run typecheck</code>	Pass	Current TypeScript compiles without emitted output.
Focused Jest suites	2/2 suites, 4/4 tests pass	G1 and program gate behavior is covered at the focused boundary.
<code>policy:gates</code>	Not run	Candidate is known ineligible; a broader run would not make G1 authentic.
<code>verify:release</code>	Not run	Release verification must not imply eligibility while G1 remains blocked.

Repository foundation

Fresh authentication	lib/security/auth-session.ts; requireFreshAuth()	Reuse for sensitive approval actions and capture an attestation snapshot.
Protected actions	services/_shared/protect.ts	Reuse permission, tenant, module-entitlement and fresh-auth enforcement.
Assurance engine	services/assurance/assurance-registry*.ts and current Prisma models	Reuse definitions, runs, findings and persistence.
Blocker lifecycle	assurance-incident.service.ts; WorkflowAssuranceIncident/Event	Reuse as canonical blocker/case lifecycle.
Control-tower UI	Assurance routes and components/assurance/*	Extend instead of building a parallel operations console.
Notifications/recovery	Assurance alert delivery/recovery and scheduler	Reuse with approval-safe redaction and new reason codes.
Evidence services	services/evidence/evidence-grade.service.ts, proof-trail.service.ts	Extend evidence subject types and export rules.
Business events/outbox	services/events/business-event.service.ts; BusinessEvent/Outbox	Reuse organization-scoped idempotency and payload hashes.
Strong domain sign-off	branch-daily-close-sign-off.service.ts and protected action	Reference pattern for source hash, fresh auth, idempotency, transaction and audit.
Domain approval UX	HRIS approval inbox service/actions/components	Reuse interaction lessons, not HRIS data semantics.
Module boundaries	services/modules/ and entitlement checks	Package and guard the capability consistently.
Graph evidence	graphify-out/GRAPH_REPORT_actions.m d, graph_actions.json	Approval/fresh-auth paths appear as several thin domain communities, supporting consolidation of common contracts while preserving domain services.

Missing runtime models

Current `prisma/schema.prisma` contains Workflow Assurance, Business Event, Compliance Evidence, Audit Log, branch-close sign-off and HRIS delegation models. It does **not** contain the proposed general `GateDefinition`, `ArtifactVersion`, `AuthorityAssignment`, `ApprovalRequest`, `ApprovalEntry`, `AuthenticationAttestation`, `EvidenceEnvelope`, `VerificationRun` or equivalent runtime aggregates. Existing design JSON is not implementation evidence.

Recommended boundary

Code or command excerpt

```
Existing Next.js actions/UI | v services/assurance/ artifacts/ authority/ policies/
approvals/ evidence-envelopes/ verification/ gates/ adapters/ | +--> existing assurance
incidents/alerts/waivers +--> existing auth/RBAC/module protection +--> existing
business event/outbox +--> domain-owned read/evidence adapters '-> optional external
e-signature adapter
```

This is a modular monolith, not a monolithic domain model. Each module exposes a bounded contract, but one application transaction can atomically record an approval, authentication attestation, audit record and outbox event.

Why not a standalone service now

- 1 It would duplicate or remotely call existing tenant, auth, assurance, alert, incident and event capabilities.

- 1 Approval writes would cross a network boundary and introduce distributed transaction/recovery problems.
- 1 Identity and tenant context would need secure propagation and independent administration.
- 1 Two control-plane representations could disagree.
- 1 There is no measured load, availability or administrative-isolation requirement that justifies extraction.

Reconsider extraction only after proven independent availability, security administration, regulated key isolation, cross-product consumption or verification throughput that harms the main application.

Capability disposition

Authority/delegation registry	New	Stable user IDs, organization and scope, provenance digest, effectivity, revocation and qualification.
Artifact registry/hashing	New plus reuse hash primitives	Immutable version, explicit canonicalization profile, bounded URI and independent recomputation.
Decision/approval policy	New	Published versions immutable; exact options, roles, quorum, sequence, SoD and freshness.
Approval orchestration	New	Explicit intent; authority and freshness rechecked at commit; append-oriented history.
Authentication attestation	New adapter/snapshot	Store assurance metadata and session reference, never secrets.
Evidence envelope	New plus evidence-service extension	Canonical JSON is the machine anchor; PDF is a presentation; both hash-verifiable.
Independent verification	New	Producer cannot silently verify own evidence; deterministic reason codes.
Gate composition	Later extension	G1 manifest adapter first; persistent graph only after parity.
Blocker lifecycle	Reuse/extend	Map failed obligations to existing Assurance incidents.
Notifications/escalation	Reuse/extend	Dedupe, redact, retry; delivery never equals approval.
Control Tower/inbox	Extend	State-complete, EN/FR, accessible; UI is not authorization.
External e-signature	Optional adapter	Signed webhooks, signer mapping, envelope/audit/final-document digests.

G1 pilot contract

Immutable source

- 1 Artifact ID: STOQUIFY-POS-G1-CONTRACT-FREEZE-0.2.0-20260817
- 1 Version: 0.2.0
- 1 Exact path: docs/pos-enterprise-grade-audit/EXECUTION_06_G1_CONTRACT_FREEZE_V0_2_0.json
- 1 Exact SHA-256: 11434eb3e1af1826516426e90d2d53a2faa47ade361d91191b5f3e0c950a36db
- 1 Decisions: D-01 through D-11
- 1 Required role obligations: 33

Pilot state flow

- 1 Register and freeze the exact artifact; reject a digest mismatch.
- 2 Import a reviewed policy version and assert exactly 11 decisions and 33 unique obligations.
- 3 Confirm authority assignments from an approved organizational source.
- 4 Route an obligation only to an active, scoped, eligible authority.
- 5 Display the exact decision option and artifact digest.
- 6 Require fresh authentication and deliberate approve/reject intent.
- 7 Recompute all identity, tenant, authority, policy, artifact and anti-replay inputs server-side.
- 8 Atomically append approval, attestation, evidence envelope, audit and outbox records.
- 9 Independently recompute and verify all obligations.
- 10 Export a read-only verified manifest for comparison with the current G1 script.
- 11 Keep the current gate authoritative and fail closed until observe-mode parity and governance acceptance.

Mandatory negative cases

- 1 Wrong tenant, session tenant or authority tenant.
- 1 Application role present but governance appointment missing.
- 1 Authority expired, revoked, conflicted or outside scope.
- 1 Fresh authentication outside the policy window.
- 1 Different option, artifact hash, policy version or request version.
- 1 Duplicate/replayed idempotency key with different content.
- 1 Same person in a prohibited SoD combination.
- 1 Evidence producer serving as prohibited verifier.
- 1 Artifact or policy drift after approval.
- 1 Existing handwritten image supplied without authenticated audit evidence.
- 1 Notification delivery or document view presented as approval intent.
- 1 Agent or service principal attempting to satisfy a human obligation.

Proposed data model controls

Logical names require a separate schema review; they are not present implementations.

Artifact / ArtifactVersion / ArtifactDigest	Tenant-safe uniqueness; frozen version immutable; explicit media/canonicalization version; onDelete: Restrict.
AuthorityAssignment / Delegation	Stable user key; provenance digest; effective period; scope; qualification; revocation/supersession; delegator authority check.
PolicyVersion / Decision / Requirement	Immutable after publish; full policy digest; option whitelist; quorum, sequence and SoD validation.
ApprovalRequest	Unique request digest/idempotency; artifact and policy binding; expiry; lifecycle version.
ApprovalEntry	Append-only decision; one active satisfaction per obligation; actor/authority/attestation references; supersession.
AuthenticationAttestation	Immutable identity, tenant, method/level, verified time and session reference; no credentials.

EvidenceEnvelope	Versioned canonical payload and digest; retention/redaction class; export references.
VerificationRun	Subject/input digest, verifier version/class/actor, deterministic checks and reason codes.
GateRun	Definition/version, dependency input manifest, evaluator version, result and invalidation chain.

All tenant-owned queries and unique keys must include `organizationId`. Evidence relationships should default to restrictive deletion and explicit retention/supersession. Database immutability claims require reviewed constraints and privileged-path controls; an application convention alone is insufficient.

Proposed API and command boundary

Representative mutations:

Code or command excerpt

```
registerArtifactVersion freezeArtifactVersion assignAuthority delegateAuthority
revokeAuthority publishDecisionPolicy createApprovalRequest recordApprovalDecision
verifyApprovalRequest invalidateControlEvidence runGateEvaluation exportEvidenceEnvelope
```

Rules for every mutation:

- 1 derive actor and `organizationId` from the trusted session;
- 1 accept resource identifiers, never trusted actor/tenant identity from the client;
- 1 parse and bound all inputs;
- 1 enforce permission, module entitlement, tenant, authority and fresh-auth requirements server-side;
- 1 recompute canonical inputs and request digest;
- 1 use idempotency with changed-payload conflict detection;
- 1 write domain state, audit and outbox atomically where possible;
- 1 return safe reason codes without secrets or cross-tenant existence leaks.

Event and invalidation design

Minimum event types:

- 1 `control.artifact.frozen`
- 1 `control.artifact.superseded`
- 1 `control.authority.assigned`
- 1 `control.authority.revoked`
- 1 `control.policy.published`
- 1 `control.approval.requested`
- 1 `control.approval.decided`
- 1 `control.approval.invalidated`
- 1 `control.evidence.envelope.created`
- 1 `control.verification.completed`
- 1 `control.gate.evaluated`
- 1 `control.gate.invalidated`

Invalidation is a first-class write, not deletion:

Code or command excerpt

```
artifact/policy/authority/evidence change -> invalidate affected approval satisfaction  
-> invalidate verification result -> invalidate gate run -> mark downstream gates  
NOT_EVALUATED -> open or update structured blocker -> notify current owner
```

Threat model

Cross-tenant approval	Unauthorized decision and data disclosure	Session-derived tenant, composite keys, tenant-filtered lookup, non-enumerating errors	Unit/integration/browser negative tests.
Forged client payload	Approval bound to unseen content	Server reconstruction, request version, anti-replay challenge and digest comparison	Tamper matrix tests.
Stale/fabricated authority	Wrong person receives decision power	Appointment provenance, effectivity, conflict state, revocation and source reconciliation	Authority lifecycle tests and governance evidence.
Authentication mistaken for authorization	Authenticated but unauthorized approval	Independent permission and authority checks	User with valid MFA but no authority is denied.
Shared or compromised authenticator	False confidence in identity	Strong account policy, fresh step-up, recovery monitoring and risk review; never claim natural-person certainty from authentication alone	Security review and recovery tests.
Replay/duplicate submission	Multiple or substituted approvals	Unique obligation/idempotency keys, payload-hash conflict, request lifecycle version	Concurrent/replay tests.
Artifact substitution	Approval applies to different bytes	Immutable artifact version, bounded storage, exact digest and independent recomputation	Golden hash and drift tests.
Canonicalization ambiguity	Different content yields disputed digest	Versioned profiles, golden vectors, exact-byte fallback for binary formats	Cross-implementation vectors.
Self-approval/SoD bypass	Fraud or control failure	Policy groups, deny-wins, actor inequality, checker independence	Policy matrix tests.
Evidence producer self-certification	Unreliable assurance	Separate verifier capability/class and immutable verifier record	Producer/verifier conflict test.
Direct API/UI bypass	Controls skipped	Service-side enforcement for every transition	Direct action/service tests.
Audit/evidence mutation	History becomes untrustworthy	Append-oriented writes, restricted update paths, supersession, backup/restore and optional external anchoring after review	Privileged-path review and restore reconciliation.
Secret/PII leakage	Privacy/security breach	Store references and assurance metadata; redact UI/logs/alerts/exports; least privilege	Data-classification and snapshot/redaction tests.
Clock manipulation	Freshness or order failure	Server time, synchronized clocks, reject future/inconsistent times	Clock-skew tests and monitoring.
Outbox/worker failure	State committed but routing/verification delayed	Transactional outbox, retry, lease recovery, dead letter and reconciliation	Failure injection and recovery runbook.
External provider spoofing	Fake signed completion	Signed webhook verification, allowlist, idempotency, signer mapping and final digests	Provider contract and replay tests.
Agent impersonation	Human control silently automated	Principal class on identities and explicit prohibition for human obligations/risk acceptance	Agent/service-principal denial tests.

Denial of service via obligation explosion	Queue and notification overload	Published-policy limits, bounded graph/role counts, rate limiting and alert dedupe	Load/property tests.

Reliability, performance and operations

The repository does not contain measured production workloads for this proposed module. Targets below are **proposals for the pilot**, not existing SLOs:

Approval commit	p95 under 750 ms excluding step-up ceremony/provider	Sensitive write should remain interactive but correctness wins over latency.
Approval read/inbox	p95 under 500 ms for bounded page	Existing dashboard pattern; paginate and index by tenant/status/assignee.
Automated G1 verification	p95 under 5 seconds after evidence available	Only 33 obligations; hashing and policy checks should be bounded.
Invalidation visibility	under 60 seconds in observe mode	Worker/outbox delay should not leave a stale pass visible for long.
Evidence export	asynchronous when artifact size exceeds a reviewed threshold	Avoid tying large PDF/storage work to request transactions.
Committed approval data loss	target RPO 0 within PostgreSQL transaction	Approval and attestation are evidence-bearing records.
Pilot service recovery	proposed RTO 4 hours	Must be approved against broader Stoquify SLOs.

Required metrics:

- 1 pending obligation count/age by gate and authority code;
- 1 authority expiry/conflict count;
- 1 stale-auth, replay, SoD and cross-tenant denial count;
- 1 verification result and lag by reason code;
- 1 drift/invalidation propagation latency;
- 1 outbox backlog, retry, dead-letter and reconciliation outcomes;
- 1 evidence export verification failure;
- 1 storage growth by tenant and retention class.

Required runbooks:

- 1 authority source unavailable or conflicting;
- 1 mistaken appointment and emergency revocation;
- 1 artifact storage unavailable or bytes changed;
- 1 verifier backlog or repeated failure;
- 1 committed approval with delayed event/notification;
- 1 evidence export mismatch or missing object;
- 1 database restore and evidence reconciliation;

- 1 provider outage or repeated/out-of-order webhook.

UX, accessibility and localization feasibility

Existing Assurance and HRIS components make the UI feasible, but the pilot must add robust states rather than only an approval button:

- 1 pending authority confirmation;
- 1 eligible and ineligible approver;
- 1 fresh-auth required/failed/recovered;
- 1 partially approved, rejected, expired and cancelled;
- 1 artifact or policy changed;
- 1 verification queued, passed or failed with reasons;
- 1 superseded approval and evidence history;
- 1 blocked dependency and next permitted action.

The UI must support keyboard-only operation, logical focus after step-up/rejection, programmatic labels and announcements, non-color cues, EN/FR terminology and permission-aware redaction. Browser behavior is evidence of usability, not the security boundary.

Migration and rollout feasibility

Safe sequence

- 1 Phase 0: approve terminology, authority source, SoD, qualification, retention and signature policy.
- 2 Review additive schema and migration design; do not modify existing evidence.
- 3 Add authority, artifact, policy, approval, attestation, envelope and verification records behind a feature flag.
- 4 Import only the exact G1 artifact and reviewed G1 policy.
- 5 Run test-tenant approval and verification flows.
- 6 Generate a runtime manifest in observe mode.
- 7 Compare with the current G1 gate and deliberately corrupt inputs.
- 8 Enable enforcement only after security, data, governance and G1 owner acceptance.
- 9 Select one second domain and repeat source/adaptor review before generalizing gates.

Rollback

- 1 Disable pilot actions, jobs and UI flags.
- 1 Stop runtime-manifest consumption and retain the current detached fail-closed gate.
- 1 Preserve all evidence-bearing records; do not destructively delete or rewrite approvals.
- 1 Correct errors through invalidation/supersession and reviewed compensating migrations.

Test and assurance plan

Unit/contract

- 1 Canonicalization golden vectors and malformed representations.
- 1 Authority effectivity, delegation, conflict and revocation.

- 1 Policy expansion, quorum, sequence and SoD.
- 1 State transitions, expiry and invalidation.
- 1 Envelope serialization and deterministic reason codes.

PostgreSQL/integration

- 1 Tenant-safe unique constraints and cross-tenant denial.
- 1 Concurrent approvals and idempotency conflicts.
- 1 Transaction rollback when audit/outbox persistence fails.
- 1 Restrictive deletion and supersession behavior.
- 1 Worker lease, retry, dead-letter and reconciliation.
- 1 Additive migration deploy/rollback rehearsal.

Browser/accessibility

- 1 Exact decision/artifact review before action.
- 1 Step-up authentication and recovery.
- 1 All empty/loading/error/stale/rejected/superseded states.
- 1 Keyboard, screen reader, focus and EN/FR content.
- 1 Permission and redaction matrix.

Adversarial/chaos

- 1 Wrong tenant and guessed resource IDs.
- 1 Payload, hash, option and policy tampering.
- 1 Stale session, shared role and revoked authority.
- 1 Duplicate/out-of-order events and webhooks.
- 1 Database commit followed by worker or storage outage.
- 1 Restore with missing projection/export and successful reconciliation without inventing approval.

Option scoring

Scores use 1 (poor) to 5 (strong). Weights total 100. They are review judgments grounded in current repository evidence, not market measurements.

A. Manual/status quo	2.68	Fastest/no build, but does not solve authentic runtime evidence or scale.
B. Narrow G1-specific implementation	3.69	Solves the immediate gate but risks another one-off contract.
C. Extend Workflow Assurance	4.46	Best reuse, tenant consistency, domain fit, reversibility and long-term option value.
D. Standalone service now	3.30	Strong isolation potential, but unjustified distributed-systems and duplication cost.
E. Buy generic approval/e-sign platform	2.70	Useful routing/signature capability; weak fit for Stoquify domain authority, hashes, dependencies and invalidation.

F. Internal core plus external e-sign adapter	3.98	Good target when legal-signature evidence is required; too broad as an initial commitment.
G. Defer all work	2.44	Preserves cash but leaves a known control and G1 workflow gap.

Weighted criteria are G1 fit (12), platform reuse (10), security/tenant safety (10), authority/policy fit (10), auditability (10), delivery speed (8), three-year TCO (8), operational complexity (7), domain flexibility (7), lock-in (5), UX (5), commercial differentiation (4) and reversibility (4).

Build conditions

Proceed with the G1 pilot only when:

- 1 governance names the authority-roster owner;
- 1 G1 authority codes and same-person/SoD rules are approved;
- 1 accepted qualification evidence for Cameroon and accounting reviewers is defined;
- 1 retention, redaction and export classes are approved;
- 1 internal attestation versus external-signature requirements are explicit;
- 1 security approves fresh-auth assurance and sensitive permissions;
- 1 data/architecture reviewers approve the additive schema and rollback design.

Do not proceed when the project would require inferred names, copied production secrets, destructive migration, weakened tenant isolation, UI-only enforcement, agent approval, or self-certification.

Feasibility conclusion

The module is technically buildable and fits the repository when implemented as a narrow extension of Workflow Assurance. The G1 pilot has a clear, bounded contract and a safe fallback. The main engineering risks—canonicalization, tenant isolation, authority correctness, append-only evidence, verification independence and invalidation—are testable.

The system is not ready for implementation merely because it is feasible. Governance decisions and a reviewed schema are prerequisite inputs, and platform-wide rollout remains an investment decision subject to the companion TCO and pilot evidence.

Primary repository evidence

- 1 docs/blockers-and-gates/BLOCKER_GATE_CONTROL_PLANE_CURRENT_STATE_ASSESSMENT_2026-08-18.md
- 1 docs/blockers-and-gates/BLOCKER_GATE_CONTROL_PLANE_TARGET_ARCHITECTURE_2026-08-18.md
- 1 docs/blockers-and-gates/BLOCKER_GATE_CONTROL_PLANE_IMPLEMENTATION_PLAN_2026-08-18.md
- 1 docs/pos-enterprise-grade-audit/EXECUTION_06_G1_CONTRACT_FREEZE_V0_2_0.json
- 1 docs/pos-enterprise-grade-audit/EXECUTION_06_G1_CONTRACT_APPROVAL_REGISTER.json
- 1 scripts/pos-g1-contract-gate.js
- 1 scripts/pos-enterprise-program-gate.js
- 1 prisma/schema.prisma
- 1 lib/security/auth-session.ts

```
1  services/_shared/protect.ts
1  services/assurance/
1  services/evidence/
1  services/events/business-event.service.ts
1  services/end-of-day-close/branch-daily-close-sign-off.service.ts
1  actions/assurance/
1  actions/hris/approval-inbox.actions.ts
1  app/[locale]/(dashboard)/dashboard/assurance/control-tower/
1  graphify-out/GRAPH_REPORT_actions.md
1  what-next/enterprise-release-blocker-status-run-20260818-r2.json
```